

📅 Published on 3 April 2026
Communiqué

Active supply chain attack targeting Axios NPM

The CSSF has been made aware of a critical supply chain attack targeting two versions of the widely used Axios HTTP client library package. Threat actors compromised maintainer accounts to inject a dependency, plain-crypto-js (specifically version 4.2.1).

As Axios is central to many architectures, a compromise of the build pipeline can result in remote code execution (RCE), credential theft, and lateral movement within the Information System. Users that performed an npm install or updated to the impacted versions of Axios within the compromised window, have likely pulled the malicious payload and should assume their system is compromised.

The CSSF recommends all supervised entities using the Axios package to implement remediation actions including at least the following:

1. Check if you use the Axios package. If your environment installed the compromised versions of Axios (1.14.1 or 0.30.4) during the breach i.e. if you ran npm install between 00:21 and 03:25 UTC on March 31, 2026, you likely pulled the malicious code. You should treat the affected systems as fully compromised. The malicious dependency is plain-crypto-js (any version, but specifically 4.2.1).
2. Immediately isolate the affected system.
3. Rotate all credentials (NPM tokens, GitHub tokens, cloud access keys, SSH keys, database keys, etc.).
4. Rebuild the system from a known clean (before 30 March 2026).
5. Block C2 infrastructure.
6. Revert to a known safe version of Axios.
7. Purge NPM cache.
8. Continually monitor for compromise.
9. Make sure you are hardened for the future e.g. MFA etc.

In addition, as this supply chain intrusion involving unauthorised malicious access constitutes a major ICT-related incident, the CSSF reminds all supervised entities that it must be notified. Notifications must be submitted according to either Circular CSSF 25/893 (DORA) or Circular CSSF 24/847, as relevant.

Keywords

- Cybersecurity [/en/search/Cybersecurity?content_keyword=2820]
- Information and communications technology (ICT) [/en/search/Information+and+communications+technology+%28ICT%29?content_keyword=2200]
- Information security [/en/search/Information+security?content_keyword=121]

🔗 Relevant for

- Central Securities Depositories (CSDs) [/en/central-securities-depositories/]
- Credit institutions [/en/credit-institutions/]
- Credit servicers [/en/credit-servicers/]

- [Crowdfunding service providers \[/en/crowdfunding-service-providers/\]](#)
- [Crypto-Assets Service Providers \(CASPs\) \[/en/crypto-assets-service-providers-casp/\]](#)
- [Data Reporting Service Providers \(DRSPs\) \[/en/data-reporting-service-provider/\]](#)
- [Investment firms \[/en/investment-firms/\]](#)
- [Investment fund managers \[/en/investment-vehicles-and-investment-fund-managers/\]](#)
- [Investment funds and vehicles \[/en/investment-vehicles-and-investment-fund-managers/\]](#)
- [Issuers of Tokens \[/en/issuers-of-tokens/\]](#)
- [Mortgage credit intermediaries \[/en/mortgage-credit-intermediaries/\]](#)
- [Payment institutions/electronic money institutions/AISPs
\[/en/payment-institutions-electronic-money-institutions-aisp/\]](#)
- [Public Oversight of the Audit Profession \[/en/public-oversight-of-the-audit-profession/\]](#)
- [Specialised PFS \[/en/specialised-pfs/\]](#)
- [Support PFS \[/en/support-pfs/\]](#)
- [Virtual Asset Service Providers \(VASPs\) \[/en/virtual-asset-service-provider/\]](#)

All rights reserved.

Copyright © Commission de Surveillance du Secteur Financier, Luxembourg